

ANSWERED QUESTIONS REPORT



F4 - LAB-WS01 Risk Assessment

6/16/2026

ISEP — Instituto Superior de Engenharia do Porto
Carlos

SELF ASSESSMENT

Disclaimer

The analysis, data, and reports in CSET® are provided “as is” for informational purposes only. The Cybersecurity & Infrastructure Security Agency (CISA) does not provide any warranties of any kind regarding any information contained within. In no event shall the United States Government or its contractors or subcontractors be liable for any damages, including but not limited to, direct, indirect, special, or consequential damages and including damages based on any negligence of the United States Government or its contractors or subcontractors, arising out of, resulting from, or in any way connected with this report, whether based on warranty, contract, tort, or otherwise, whether injury was sustained from, or arose out of the results of, or reliance upon the report.

CISA does not endorse any commercial product or service, including the subject of the assessment or evaluation in this report. Any reference to specific commercial products, processes, or services by trademark, manufacturer, or otherwise, does not constitute or imply its endorsement, recommendation, or favoring by CISA.

The display of the CISA official seal or other CISA visual identities on this report shall not be interpreted to provide the recipient organization authorization to use the official seal, insignia or other visual identities of CISA. The CISA seal, insignia, or other visual identities shall not be used in any manner to imply endorsement of any commercial product or activity by CISA or the United States Government. Use of the CISA seal without proper authorization violates federal law (e.g., 18 U.S.C. §§ 506, 701, 1017), and is against CISA policies governing usage of the seal.

The report is prepared and intended for internal use by the organization that made the request. The contents of this report may be subject to government or private intellectual property rights. To request distribution of this report outside the organization for which it was prepared, contact the CSET Program Office. The contents of this report may be reproduced or incorporated into other reports, but may not be modified without the prior express written permission of the CSET Program Office.

Advisory

The Cyber Security Evaluation Tool (CSET®) is only one component of the overall cybersecurity picture and should be complemented with a robust cyber security program within the organization. A self-assessment with CSET® cannot reveal all types of security weaknesses, and should not be the sole means of determining an organization's security posture.

The tool will not provide a detailed architectural analysis of the network or a detailed network hardware/software configuration review. It is not a risk analysis tool so it will not generate a complex risk assessment. CSET® is not intended as a substitute for in-depth analysis of control system vulnerabilities as performed by trained professionals. Periodic onsite reviews and inspections must still be conducted using a holistic approach including facility walk-downs, interviews, and observation and examination of facility practices. Consideration should also be given to additional steps including scanning, penetration testing, and exercises on surrogate, training, or non-production systems, or systems where failures, unexpected faults, or other unexpected results will not compromise production or safety.

CSET® assessments cannot be completed effectively by any one individual. A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential. The representatives must be subject matter experts with significant expertise in their respective areas. No one individual has the span of responsibility or knowledge to effectively answer all the questions.

Data and reports generated by the tool should be managed securely and marked, stored, and distributed in a manner appropriate to their sensitivity.

Question Details: SP800-171 R2

Access Control - 3.1.1	Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).	Yes
Security Assessment - 3.12.4	Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.	Yes
Access Control - 3.1.2	Limit system access to the types of transactions and functions that authorized users are permitted to execute.	Yes
Access Control - 3.1.3	Control the flow of CUI in accordance with approved authorizations.	No
Access Control - 3.1.4	Separate the duties of individuals to reduce the risk of malevolent activity without collusion.	No
Access Control - 3.1.5	Employ the principle of least privilege, including for specific security functions and privileged accounts.	No
Access Control - 3.1.6	Use non-privileged accounts or roles when accessing non-security functions.	No

Access Control - 3.1.7	Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.	No
Access Control - 3.1.8	Limit unsuccessful logon attempts.	Yes
Access Control - 3.1.9	Provide privacy and security notices consistent with applicable CUI rules.	No
Access Control - 3.1.10	Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity.	Yes
Access Control - 3.1.11	Terminate (automatically) a user session after a defined condition.	Yes
Access Control - 3.1.12	Monitor and control remote access sessions.	No
Access Control - 3.1.13	Employ cryptographic mechanisms to protect the confidentiality of remote access sessions.	Yes
Access Control - 3.1.14	Route remote access via managed access control points.	No
Access Control - 3.1.15	Authorize remote execution of privileged commands and remote access to security-relevant information.	No
Access Control - 3.1.16	Authorize wireless access prior to allowing such connections.	No

Access Control - 3.1.17	Protect wireless access using authentication and encryption.	No
Access Control - 3.1.18	Control connection of mobile devices.	No
Access Control - 3.1.19	Encrypt CUI on mobile devices and mobile computing platforms.	N/A
Access Control - 3.1.20	Verify and control/limit connections to and use of external systems.	Yes
Access Control - 3.1.21	Limit use of portable storage devices on external systems.	No
Access Control - 3.1.22	Control CUI posted or processed on publicly accessible systems.	N/A
Awareness and Training - 3.2.1	Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.	No
Awareness and Training - 3.2.2	Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.	No
Awareness and Training - 3.2.3	Provide security awareness training on recognizing and reporting potential indicators of insider threat.	No

Audit and Accountability - 3.3.1	Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity.	Yes
Audit and Accountability - 3.3.2	Ensure that the actions of individual information system users can be uniquely traced to those users so they can be held accountable for their actions.	Yes
Audit and Accountability - 3.3.3	Review and update logged events.	No
Audit and Accountability - 3.3.4	Alert in the event of an audit logging process failure.	No
Audit and Accountability - 3.3.5	Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.	No
Audit and Accountability - 3.3.6	Provide audit record reduction and report generation to support on-demand analysis and reporting.	No
Audit and Accountability - 3.3.7	Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.	No
Audit and Accountability - 3.3.8	Protect audit information and audit logging tools from unauthorized access, modification, and deletion.	Yes

Audit and Accountability - 3.3.9	Limit management of audit logging functionality to a subset of privileged users.	Yes
Configuration Management - 3.4.1	Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.	Yes
Configuration Management - 3.4.2	Establish and enforce security configuration settings for information technology products employed in organizational systems.	Yes
Configuration Management - 3.4.3	Track, review, approve or disapprove, and log changes to organizational systems.	Yes
Configuration Management - 3.4.4	Analyze the security impact of changes prior to implementation.	Yes
Configuration Management - 3.4.5	Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.	No
Configuration Management - 3.4.6	Employ the principle of least functionality by configuring organizational systems to provide only essential capabilities.	Yes
Configuration Management - 3.4.7	Restrict, disable, and prevent the use of nonessential programs, functions, ports, protocols, and services.	No

Configuration Management - 3.4.8	Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-exception (whitelisting) policy to allow the execution of authorized software.	No
Configuration Management - 3.4.9	Control and monitor user-installed software.	No
Identification And Authentication - 3.5.1	Identify system users, processes acting on behalf of users, and devices.	Yes
Identification And Authentication - 3.5.2	Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.	Yes
Identification And Authentication - 3.5.3	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.	No
Identification And Authentication - 3.5.4	Employ replay-resistant authentication mechanisms for network access to privileged and non-privileged accounts.	Yes
Identification And Authentication - 3.5.5	Prevent reuse of identifiers for a defined period.	Yes

Identification And Authentication - 3.5.6	Disable identifiers after a defined period of inactivity.	No
Identification And Authentication - 3.5.7	Enforce a minimum password complexity and change of characters when new passwords are created.	Yes
Identification And Authentication - 3.5.8	Prohibit password reuse for a specified number of generations.	Yes
Identification And Authentication - 3.5.9	Allow temporary password use for system logons with an immediate change to a permanent password.	Yes
Identification And Authentication - 3.5.10	Store and transmit only cryptographically-protected passwords.	Yes
Identification And Authentication - 3.5.11	Obscure feedback of authentication information.	No
Incident Response - 3.6.1	Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.	No

Incident Response - 3.6.2	Track, document, and report incidents to designated officials and/or authorities both internal and external to the organization.	No
Incident Response - 3.6.3	Test the organizational incident response capability.	No
Maintenance - 3.7.1	Perform maintenance on organizational systems.	Yes
Maintenance - 3.7.2	Provide controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.	No
Maintenance - 3.7.3	Ensure equipment removed for off-site maintenance is sanitized of any CUI.	No
Maintenance - 3.7.4	Check media containing diagnostic and test programs for malicious code before the media are used in organizational systems.	Yes
Maintenance - 3.7.5	Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.	No
Maintenance - 3.7.6	Supervise the maintenance activities of maintenance personnel without required access authorization.	No

Media Protection - 3.8.1	Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.	No
Media Protection - 3.8.2	Limit access to CUI on system media to authorized users.	Yes
Media Protection - 3.8.3	Sanitize or destroy system media containing CUI before disposal or release for reuse.	No
Media Protection - 3.8.4	Mark media with necessary CUI markings and distribution limitations.	No
Media Protection - 3.8.5	Control access to media containing CUI and maintain accountability for media during transport outside of controlled areas.	No
Media Protection - 3.8.6	Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.	No
Media Protection - 3.8.7	Control the use of removable media on system components.	No
Media Protection - 3.8.8	Prohibit the use of portable storage devices when such devices have no identifiable owner.	No
Media Protection - 3.8.9	Protect the confidentiality of backup CUI at storage locations.	No

Personnel Security - 3.9.1	Screen individuals prior to authorizing access to organizational systems containing CUI.	No
Personnel Security - 3.9.2	Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.	No
Physical Protection - 3.10.1	Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.	No
Physical Protection - 3.10.2	Protect and monitor the physical facility and support infrastructure for organizational systems.	No
Physical Protection - 3.10.3	Escort visitors and monitor visitor activity.	No
Physical Protection - 3.10.4	Maintain audit logs of physical access.	No
Physical Protection - 3.10.5	Control and manage physical access devices.	No
Physical Protection - 3.10.6	Enforce safeguarding measures for CUI at alternate work sites.	No

Risk Assessment - 3.11.1	Periodically assess the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals, resulting from the operation of organizational systems and the associated processing, storage, or transmission of CUI.	Yes
Risk Assessment - 3.11.2	Scan for vulnerabilities in organizational systems and applications periodically and when new vulnerabilities affecting those systems and applications are identified.	Yes
Risk Assessment - 3.11.3	Remediate vulnerabilities in accordance with risk assessments.	Yes
Security Assessment - 3.12.1	Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.	Yes
Security Assessment - 3.12.2	Develop and implement plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems.	Yes
Security Assessment - 3.12.3	Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.	No

System and Communications Protection - 3.13.1	Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.	No
System and Communications Protection - 3.13.2	Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.	Yes
System and Communications Protection - 3.13.3	Separate user functionality from system management functionality.	Yes
System and Communications Protection - 3.13.4	Prevent unauthorized and unintended information transfer via shared system resources.	No
System and Communications Protection - 3.13.5	Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.	Yes
System and Communications Protection - 3.13.6	Deny network communications traffic by default and allow network communications traffic by exception (i.e., deny all, permit by exception).	No

System and Communications Protection - 3.13.7	Prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other connection to resources in external networks (i.e., split tunneling).	No
System and Communications Protection - 3.13.8	Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.	No
System and Communications Protection - 3.13.9	Terminate network connections associated with communications sessions at the end of the sessions or after a defined period of inactivity.	Yes
System and Communications Protection - 3.13.10	Establish and manage cryptographic keys for cryptography employed in organizational systems.	No
System and Communications Protection - 3.13.11	Employ FIPS-validated cryptography when used to protect the confidentiality of CUI.	No
System and Communications Protection - 3.13.12	Prohibit remote activation of collaborative computing devices and provide indication of devices in use to users present at the device.	No
System and Communications Protection - 3.13.13	Control and monitor the use of mobile code.	No

System and Communications Protection - 3.13.14	Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.	No
System and Communications Protection - 3.13.15	Protect the authenticity of communications sessions.	Yes
System and Communications Protection - 3.13.16	Protect the confidentiality of CUI at rest.	No
System And Information Integrity - 3.14.1	Identify, report, and correct system flaws in a timely manner.	Yes
System And Information Integrity - 3.14.2	Provide protection from malicious code at designated locations within organizational systems.	Yes
System And Information Integrity - 3.14.3	Monitor system security alerts and advisories and take action in response.	No
System And Information Integrity - 3.14.4	Update malicious code protection mechanisms when new releases are available.	No
System And Information Integrity - 3.14.5	Perform periodic scans of organizational systems and real-time scans of files from external sources as files are downloaded, opened, or executed.	Yes

System And Information Integrity - 3.14.6	Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.	No
System And Information Integrity - 3.14.7	Identify unauthorized use of organizational systems.	No